Executive Summary

1. Purpose and scope

Cathy has made her business fully digital, transforming it into an online supply chain backed by a network of global automated warehouses. Two potential customers, HRH the King and Prince Albert II of Monaco, have expressed interest; and, whilst both have the same concern, they at least are raising it: will the new technology affect product quality or security of supply? This briefing gives a substantive reply to this question, quantifying the risks of quality and availability loss, and illustrating the business's continuous operation, 24 hours a day, 7 days a week, 365 days a year, with a changeover window and data-loss exposure of less than one minute.

Throughout, risk is treated in the way Aven and Thekdi (2025, chapter 2) define it: the consequences of an activity together with the uncertainty attached to them, written as (C,U), or as (A,C,U) when an initiating event A is identified and C is the outcome given that event. Their descriptive scheme (A’,C’,Q,K) is also used below, where A’ and C’ are the events and consequences considered, Q expresses the uncertainty about them, and K is the knowledge the judgements rest on (Aven and Thekdi, 2025, chapter 3). Every figure in this document therefore carries a judgement about how much we know, which is the discipline the brief asks for.

2. Risk Identification

I listed the sources of risk, threats and hazards before beginning quantification, in a similar fashion to the risk assessment process in the main book (Aven and Thekdi, 2025, chapter 4). Two different methods were adopted together. A threat model based on STRIDE was used on the automated warehousing and e-commerce estate, because STRIDE addresses the question of how something could be attacked rather than just how it might fail (OWASP, 2024). Attack trees dissected the highest impact threat, disruption of an automated warehouse, into possible pathways to it.

That research identified two categories of risk. The first relates to the product itself. Automation replaces some of the tacit human judgement that a luxury producer has generally relied on; the principal practical risks are sensor drift, calibration failure, a temperature excursion during transit, and the loss of quality control if production has been distributed across several locations. The second category relates to the supply chain. Moving production around the globe increases the attack surface and creates additional single points of failure, so the risks include reliance on a narrow set of critical suppliers, logistics congestion, ransomware attacks on operational technology, and data corruption spreading between interconnected computers.

Both clusters relate to the interests recently expressed by potential clients: integrity for quality and availability for supply, rather than confidentiality, so these aspects of CIA are followed in the analysis.

3. Method Selection, and its limitations

Different quantitative approaches could be applied to the problem the business is currently tackling. Monte Carlo simulation was selected as suited using the FAIR breakdown of risk into frequency of loss, events and cost of the loss, events themselves (Hubbard and Seiersen, 2023; Aven and Thekdi, 2025, chapter 5). The technique is appropriate for three reasons: it gives probabilities and loss distributions as the clients requested; it can handle the meagre historical data any new operating model can expect; it helps sensitivity analysis, allowing the managers to identify key drivers.

There are also weak points with this choice that need pointing out. This method is only as good as the distributions provided; weak elicitation will lead to distributions that look plausible but be flawed. As the scoring methods, this method is also more computationally complex and makes stronger assumptions about those using the output than we would like. Lastly, assuming independence between the variables makes the model look better than it is in the cases where the variables do in fact co, vary. I have attempted to address these points by stating the assumed minimum, modal, and maximum values for every input, making the modelling process more transparent and including an explicit correlation

term, although none of these design features eliminate the problem altogether. These numbers should guide your decision, not determine it.

Two other options were dismissed. A better method is the Bayesian approach to the threshold, based loss questions here, but it would be advantageous when real incident data was available. Multi, criteria methods like AHP and TOPSIS, covered by Taherdoost and Madanchian (2023) combine judgements into a single preference value and do not generate the distribution of frequency, and, magnitude the brief asks for.

4. Assumptions and data

- **Simulation:** 200, 000 runs per scenario, with a fixed seed so each of the figures below can be exactly replicated. The frequency of loss events was modelled as a Poisson process, with rate set to reproduce the assumed probability of at least one event per year, and the size of each event as a lognormal severity fit to the assumed minimum, most, likely, and maximum, recognizing this is usually as skewed distribution expert judgement about new risks.
- **Quality risk:** frequency and consequence are modelled assumptions based on failure modes described in Section 2. Magnitude expressed as percentage of revenue in potential rework, recall, or damage to reputation.
- **Supply risk:** probability and severity are modelled estimates, based on incident rates in sector survey reports (BCI, 2023; PwC, 2023) and scaled to the firm's size, rather than based on values from these reports.
- **Correlation:** cyber, attack frequency and logistics disruption were linked by a Gaussian copula calibrated to a rank correlation of approximately 0.3, reflecting the tendency for the two to coincide during peak trading periods. The copula adds the dependence without disturbing the individual distributions.
- **Horizon and currency:** all sizes are in EUR over a single year.
- **Stated limitation:** where no internal data existed, informed judgement was taken rather than measured frequencies. This means that the amount of uncertainty is increased and is declared rather than remaining hidden.

5. **Results**

Risk scenario	**Annual probability of a loss event**	**95th-percentile loss**
Loss of product quality (cold-chain or sensor failure)	6.3%	€0.46m
Loss of quality through loss of craft oversight	11.3%	€0.40m
Supply chain: cyber-attack or ransomware on automated warehouses	17.4%	€2.43m
Supply chain: key-supplier dependency failure	21.0%	€0.84m
Supply chain: logistics or congestion disruption	14.8%	€0.84m
Supply chain: data-integrity corruption across systems	9.6%	€0.40m

As the model, the probability of the entire adverse quality, loss event occurring in any given year was slightly below 17%, with a heavily, right skewed tail: while the mean annual loss for all scenarios was close to 0.8m, the 99th, percentile combined loss was 6.4m, in part driven by a small number of correlated cyber, and, logistics events. Sensitivity analysis revealed one dominant driver: approximately three, quarters of the variance of the combined loss distribution was caused by the frequency of cyber-attacks on warehouse operational technology, followed by logistical disruption at around one, tenth, with supplier concentration at around six per cent. Intervention that means does not simply reallocate risk around the firm, but a lot alters its overall profile.

If the inputs are judgment, based, the result indicates current beliefs, with only moderate, to, strong certainty in the knowledge underlying the answer, as Aven and Thekdi say. The point of this activity is not to quantify the numbers, but to reveal the uncertainty and make

it comparable so that the money spent can be defended against a transparent logic rather than intuition.

6. Recommendations

The recommendations are ranked by commercial exposure, starting with the risk most likely to damage the client relationship and revenue.

Priority 1. Protect the supply chain from cyber-attack (17.4%) Warehouse operational technology should be separated from corporate networks, with segmentation, least privilege and continuous monitoring (NIST, 2024). This is the highest probability and impact weighted loss, the greatest concern of the clients, and the number one priority at this point.

Priority 2. Minimize key supplier reliance (~21%). Dual, sourcing of strategic components tackles the most likely failure mode and would normally be the control most frequently delayed for reasons of cost. (Christopher, 2016). Thinking about how the odds work out, these costs are hard to justify.

Priority 3. Ensure product quality controls are maintained for automation (17%, overall) human quality gates operate alongside automated sensing, and the cold chain is fitted with tamper, evident logging. This underpins most closely the product quality that the clients are paying for.

Priority 4. Data, integrity controls (~9.6%). Reconciliation and referential, integrity checks between say the order entry and billing systems will ensure invalid data does not silently cascade between them.

Priority 5. Standards and GDPR compliance (business critical) Digitalization presents a data protection issue of the same order as an operational one, and risks should be designed into it from the beginning rather than designed out. Cross, border transfer of personal data down a supply chain implicates restrictions on the transfer of data to third countries to the UK and the EU GDPR (Regulation (EU) 2016/679, 2016; Data Protection Act 2018). This means a Data Protection Impact Assessment must be carried out before any new automated location, Standard Contractual Clauses or an adequacy decision

must be used in cross, border processing and the overall assurance model set within the structure of ISO 31000 and NIST (ISO, 2018; NIST, 2024).

The programme and presents ethical and professional considerations. The aggregation of sensitive data across automated warehouses increases the firm's duty of care to the individuals whose information it handles at scale, and a breach's reputational cost must be measured alongside its dollar figure. So, the practitioner should try to measure commercial, legal, and ethical pressures against each other rather than optimize.

7. Business continuity and disaster recovery

A Business Continuity Plan starts with a Business Impact Assessment, which is where these two defining variables for the plan in this instance are extracted (Wallace and Webber, 2017). Ms. O'dour's specifications boil down to a recovery time objective (changeover time) of less than 1 minute and a recovery point objective (maximum tolerable data loss) of less than 1 minute. These extreme tight parameters are at the harsh end of the spectrum of resilience and preclude standard backup, and restore styles, which would be looking at hours (Wallace and Webber, 2017).

To meet them, I recommend an active, active, multi, region deployment with synchronous replication and automated, health, check, driven failover. Global load balancing would direct traffic between regions while database state is kept synchronized, producing a sub, minute RTO and RPO. The plan must be automated and rehearsed; the core text lists exercises and drills among the instruments of resilience management (Aven and Thekdi, 2025, chapter 8), so failover should be exercised on a regular schedule.

When hosting, go with a hyperscale provider that has paired regions in a single jurisdiction (e.g. AWS or Microsoft Azure paired UK/EU regions) and choose this pair for native synchronous replication and managed failover. This can be a Do, It, yourself style design or, more cheaply, Disaster Recovery as a Service, which reduces capital and Operating expenditure at the cost of ceding some control to the provider. Vendor lock-in is honest about the answer: while proprietary services will in fact gradually increase the cost of exit (Opara, Martins, Sahandi and Tian, 2016), the exposure of a lock-in, while reduced, is not removed by infrastructure, as, code, containerization, or open data formats, so fund a

periodic exit test rather than assume portability. Design network security in from the beginning as replication can unfortunately propagate a compromised state as readily as a healthy one. One caveat: while regions must be far enough apart to fail independently, they should also be close enough to meet these GDPR requirement.

8. **Conclusion**

Modelling suggests that digitalization does not inherently threaten product quality, although it does increase the probability of supply, chain disruption, mainly due to supplier dependency and cyber-attacks. The likelihood of any quality, loss event within a year is about 17%, with the most probable single loss, key, supplier failure, approaching 21%. These figures are commercially significant and support the mitigation sequence described above. And an active, active, synchronously replicated cloud architecture can achieve the one, minute RTO and RPO, provided the continuity plan is automated, rehearsed, and includes GDPR, compliant transfer mechanisms from the outset. These recommendations give the company a basis for the assurance its premium clients require, while keeping the strategy aligned with the evolving risk landscape, where automation and artificial intelligence continue to reshape both threats and available defenses (Aven and Thekdi 2025 chapter 12; Dwivedi et al 2021).

References

Aven, T. and Thekdi, S. (2025) *Risk Science: An Introduction*. 2nd edn. Abingdon: Routledge. Available at: https://doi.org/10.4324/9781003494317

BCI (2023) *BCI Supply Chain Resilience Report 2023*. Available at: https://www.thebci.org/static/340ffa9b-03b4-4baf-9add7071cbbea758/BCI-Supply-Chain-Resilience-Report-2023.pdf (Accessed: 11 October 2026).

Christopher, M. (2016) *Logistics and Supply Chain Management*. 5th edn. Harlow: Pearson.

Data Protection Act 2018, c. 12. United Kingdom. Available at: https://www.legislation.gov.uk/ukpga/2018/12/contents/enacted (Accessed: 11 October 2026).

Dwivedi, Y.K. *et al.* (2021) 'Artificial Intelligence (AI): multidisciplinary perspectives on emerging challenges, opportunities, and agenda for research, practice and policy', *International Journal of Information Management*, 57, 101994. Available at: https://doi.org/10.1016/j.ijinfomgt.2019.08.002

Hubbard, D.W. and Seiersen, R. (2023) *How to Measure Anything in Cybersecurity Risk*. 2nd edn. Hoboken, NJ: Wiley.

ISO (2018) *ISO 31000:2018 Risk management Guidelines*. Geneva: International Organization for Standardization. Available at: https://www.iso.org/standard/65694.html (Accessed: 11 October 2026).

NIST (2024) *The NIST Cybersecurity Framework (CSF) 2.0*. Gaithersburg, MD: National Institute of Standards and Technology. Available at: https://doi.org/10.6028/NIST.CSWP.29

Opara-Martins, J., Sahandi, R. and Tian, F. (2016) 'Critical analysis of vendor lock-in and its impact on cloud computing migration: a business perspective', *Journal of Cloud Computing*, 5, 4. Available at: https://doi.org/10.1186/s13677-016-0054-z

OWASP (2024) *Threat Modeling Cheat Sheet*. Available at: https://cheatsheetseries.owasp.org/cheatsheets/Threat_Modeling_Cheat_Sheet.html (Accessed: 11 October 2026).

PwC (2023) *Global Digital Trust Insights 2024*. Available at: https://www.pwc.com/hu/hu/kiadvanyok/assets/pdf/pwc-2024-global-digital-trust-insights.pdf (Accessed: 11 October 2026).

Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data (General Data Protection Regulation) (2016) *Official Journal* L 119, 4 May, pp. 1–88. Available at: https://eur-lex.europa.eu/eli/reg/2016/679/oj (Accessed: 11 October 2026).

Taherdoost, H. and Madanchian, M. (2023) 'Multi-criteria decision making (MCDM) methods and concepts', *Encyclopedia*, 3(1), pp. 77–87. Available at: https://doi.org/10.3390/encyclopedia3010006

Wallace, M. and Webber, L. (2017) *The Disaster Recovery Handbook*. 3rd edn. New York: AMACOM.